ADMINISTRATION · EVERYONE

# 1 · Sign-in, roles and access

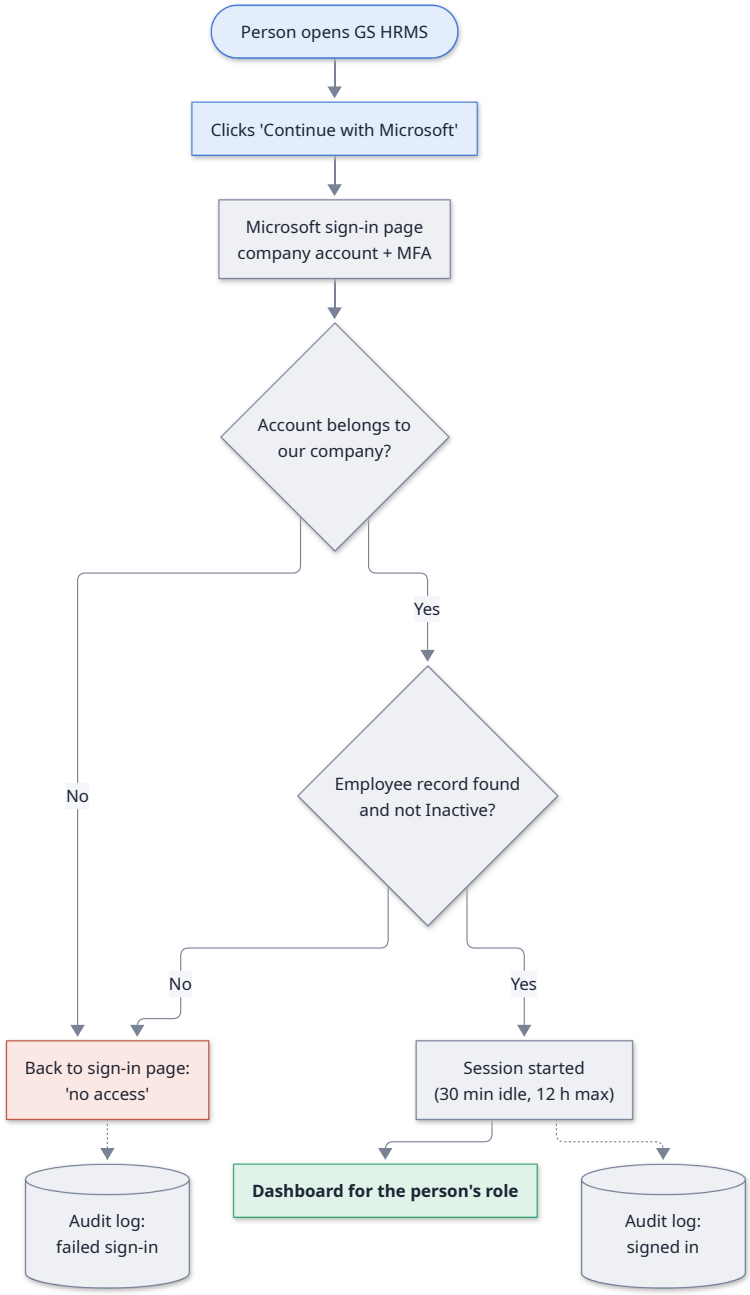
Who can get into the system, and what each person is allowed to see and do once inside.

| | |
|---|---|
| **Used by** | Everyone Super Admin manages roles |
| **Frontend** | `/login` , `/admin/roles` , `lib/auth.ts` , `lib/access.ts` , `lib/guard.ts` , `lib/nav.ts` |
| **Backend** | Phase 0 — sign-in, sessions, the access check and the Roles & Permissions API are built and connected to the frontend; the two Talent Acquisition roles and data scopes are next |

## In short

1. Everyone signs in with their **Microsoft 365** work account (with MFA). There are no separate HRMS passwords.
2. Each person has one **role**: Employee, Team Lead, Recruiter, Talent Acquisition Manager, HR, Office Admin or Super Admin (or a custom role).
3. The role decides which **screens** appear and which **actions** (view, add, edit, delete) are allowed.
4. Data is limited to the person's **scope**: own records, direct reports, their location, or everyone.

## Signing in

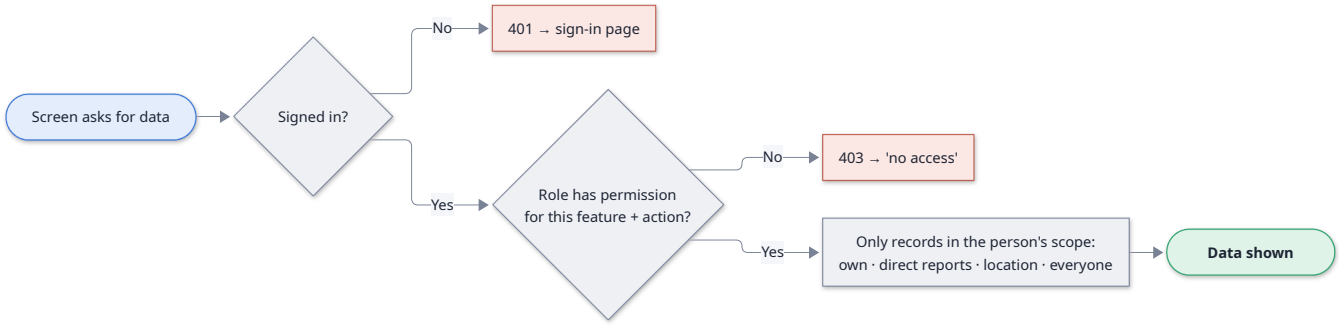



**Until Microsoft sign-in is set up**, the sign-in page has an email + password form that works only for the fictional demo accounts (one per role, listed on the page). The server checks the shared demo password, gives the same "email or password is incorrect" answer for any mistake, slows down repeated attempts, and audits every try.

1. Everyone signs in with their **Microsoft 365 work account**. Microsoft checks the password and MFA; GS HRMS never stores passwords.
2. The system looks for the employee record that belongs to that Microsoft account. On the very first sign-in it links them by work email.
3. People who are **Inactive** (left the company) or not in the system cannot get in.
4. The session ends after **30 minutes without activity**, after **12 hours** in total, on sign-out, or immediately when the employee is offboarded.

5. Every sign-in, sign-out and failed attempt is written to the audit log.

## Every request is checked




## Roles, spaces and permissions

| Role | My Space | Team | Organization | Operations / Reports / Admin | Data scope |
|---|---|---|---|---|---|
| Employee | ✔ | | | | Own records |
| Recruiter | ✔ | | | Hiring → Recruiting only (no delete) | Own records; jobs assigned to them |
| Team Lead | ✔ | ✔ | | | Own + direct reports |
| Talent Acquisition Manager | ✔ | ✔ | | All of Hiring (no delete) | Own + direct reports; all hiring |
| HR | ✔ | | ✔ | ✔ (no delete in Administration) | All locations |
| Office Admin | ✔ | | ✔ | ✔ (never delete) | Own location |
| Super Admin | ✔ | ✔ | ✔ | ✔ | Everything |

- Permissions are set per **feature** with four actions: **View, Add, Edit, Delete**. Add/Edit/Delete always need View.
- Features are grouped Module → Category → Feature (for example *Administration* → *Organization* → *Companies*).
- Super Admin can create **custom roles** (from scratch, by duplicating a role, or by copying another role's access), tick permissions per feature, compare up to four roles side by side, and add custom features. System roles cannot be renamed.
- Nobody can change their own role, give access they do not have themselves, or change the Super Admin role. When a role's access changes, everyone with that role is signed out so the change applies at once.
- "Team" means **direct reports only**, not the whole tree below a manager.

**Not in the frontend yet**

- "Continue with Microsoft" is a placeholder; sign-in uses the demo email + password form against the server.
- Menus and buttons still follow the frontend's built-in role defaults, not the permissions the server returns; a custom role is shown as Employee.
- Roles & Permissions is saved on the server, but "Add feature" is switched off and there is no screen yet to give someone a role.
- The backend does not have the **Talent Acquisition Manager** and **Recruiter** roles or their demo accounts yet, and "Team → Requests" is missing from its permission list.